

性,可扩展性、智能化的需求,使工作更加轻松有效,整体运作更加协调,从而最终满足高质量网络服务的目的。当然,随着ICT领域的不断发展,我们还有不少可以改进的地方,例如,采用全光纤来进行数据加密以保障带宽安全,采用冗余度更好的虚拟化技术来进行冗余备份,将人工智能与雾计算技术结合应用,帮助物联网的应用更智慧。相信经过优化后的企业网络规划,一定会为企业提供有力的保障。

参考文献:

[1]张焱,杨贵莲,徐柯,向梅梅,韦珊. 基于 IPSec-VPN

解决跨地域公司内网互访网络的设计[J]. 中小企业管理与科技, 2018 (05): 160-200.

[2]郭琳. 中小企业多路由协议互连网络规划与实现[J]. 软件导刊, 2020 (11): 105-120.

[3]蹇巍, 郭萌. 国内大型建筑中央企业全球网络规划与设计[J]. 电子技术与软件工程, 2019 (04): 278-312.

[4]黄宏杰. DMVPN 技术在企业网中的应用研究[J]. 计算机时代, 2019 (20): 96-102.

[5]黄丽丽. 物联网技术在智能家居中的应用分析[J]. 数字技术与应用, 2022 (09): 100-110.

等级保护 2.0 中渗透测试技术的研究

◆田嘉豪 胡吉祥

(陕西省网络与信息安全测评中心 陕西 710065)

摘要: 等保 2.0 是中国国家互联网信息办公室制定的网络安全标准,旨在保障我国互联网安全,其中包括渗透测试内容。渗透测试是指企业的信息安全测试,可以确保网络、应用程序和系统的安全性。渗透测试就是测试人员使用攻击手段,模拟黑客的攻击方式,以达到及时发现的漏洞,分析和评估漏洞的危害度,提供针对漏洞及时、有效的修复方案,使信息、业务在网络中得到保护。本篇文章从以下几个方面介绍等保 2.0 中的渗透测试。

关键词: 等保 2.0; 渗透测试

1 等保 2.0 由来

等保 2.0 是中国国家互联网信息办公室推出的网络安全等级保护制度的升级版。其由来是因为随着中国互联网技术的快速发展,网络威胁和风险也日益增加,互联网的基础设施和关键信息系统面临着更大的安全挑战。为了更好地保护国家信息安全,中国政府不断推进互联网安全相关工作,并逐步完善网络安全等级保护制度。等保 2.0 是在对原有制度的总结和借鉴全球网络安全先进经验的基础上,进一步提高了网络安全保护等级的标准和要求,更好地适应当前和未来的网络安全形势。

2 渗透测试的必要性

根据《信息系统安全等级保护测评要求》,对于安全等级在三级及以上的信息系统,必须进行渗透测试。等保 2.0 渗透测试是按照国家标准进行测试,通过完成等保 2.0 渗透测试可以证明企业或组织符合相关国家信息安全法律法规和标准,旨在模拟真实攻击,测试网络访问控制、边界设备、主要网络设备、主要服务器操作系统网络设备以及主要应用程序的安全性。

随着信息技术的快速发展,各种安全漏洞不断涌现,带来了越来越多的潜在风险。因此,在等级保护测评中,及时、准确地发现信息系统的安全漏洞,判断安全状况变得非常迫切和必要。

渗透测试的意义在于通过模拟黑客攻击来发现并修补客户公司的漏洞,以保护企业的安全。在日常网络环境中,常常出现新的威胁和漏洞,因此渗透测试可以及时发现漏洞,提供有效的安全解决方案。

3 渗透测试概述

渗透测试是指企业的信息安全测试,可以确保网络、应用程序和系统的安全性。渗透测试就是测试人员使用攻击手

段,模拟黑客的攻击方式,以达到及时发现的漏洞,分析和评估漏洞的危害度,提供针对漏洞及时、有效的修复方案,使信息、业务在网络中得到保护。渗透测试通常涉及计算机安全、网络安全、Web 应用程序安全等方面。

通过模拟恶意攻击,渗透测试的目的是发现可能导致漏洞的系统或程序的弱点。测试结果将用于评估系统或程序的安全性,以确定需要改进的地方。

4 渗透测试的流程

在等保 2.0 中,渗透测试被规定为由一系列活动和测试组成的流程。这些活动和测试主要包括:

(1) 情报收集

情报收集是指通过各种公开/可用渠道,以便了解该公司的有关信息,包括架构、网站、服务器、IP 地址、电话号码、人员信息等。

(2) 手动测试

手动测试涉及通过尝试不同的攻击方法,手动验证系统或应用程序的安全性。

(3) 自动化测试

自动化测试是指使用自动化测试工具来加速测试过程。这种测试可以覆盖系统或应用程序的更大范围,并发现那些手动测试可能无法发现的漏洞。

(4) 安全审核

安全审核是指在系统或应用程序的代码上执行安全审查,以寻找可能导致漏洞的漏洞和其他问题。这种测试可以通过识别和修复代码中的漏洞来增强程序的安全性。

(5) 社会工程学测试

社会工程学测试是指通过惯用手段实现以获取敏感信息、访问多达的登录等来验证公司的员工能够识别和抵抗钓鱼攻击。

(6) 报告中漏洞信息

最后,渗透测试结果将被记录在安全评估报告中。这份

报告将列出测试过程中发现的漏洞，并提供修复这些漏洞的建议。报告还将评估系统或应用程序的总体安全性水平。

5 渗透测试的类型

在等保 2.0 中，渗透测试分为以下几类：

(1) 外网测试

外网测试是指在测试系统或应用程序的外部安全性。它涉及模拟对系统或应用程序的外部攻击，以寻找系统或应用程序中的漏洞和弱点，从而修复它们。

(2) 内部网络测试

内部测试是指在测试系统或应用程序的内部安全性。这种测试涉及模拟从公司内部的网络进行攻击，以寻找内部网络的漏洞和弱点。

(3) 物理安全测试

物理安全测试是指测试系统或应用程序的物理安全措施的有效性。这种测试通常涉及进入公司的办公室、机房等物理空间，以寻找可能导致漏洞的弱点和安全缺陷。

(4) 无线网络测试

无线网络测试是指测试无线网络的安全性。这种测试通常在用户持有的 Wi-Fi 网络上进行，通过模拟黑客攻击，并在测试中发现漏洞和弱点。

6 总结

在等保 2.0 标准中，渗透测试是确定网络安全性的十分重要的措施。执行和报告其结果的重要性不可忽略，渗透测试将帮助组织发现网络安全漏洞和其他弱点，进一步加强其安全性，保护数据、资产和企业形象。但是，由于渗透测试可能会暴露系统或应用程序中的漏洞或弱点，因此如果组织无法及时纠正这些问题，渗透测试可能对组织造成进一步的风险。因此，执行渗透测试的操作者需要根据测试的结果及时进行修复和优化，以确保该组织在网络环境中的安全性。

参考文献

[1]严浩,石西华.渗透测试在网络安全等保测评中的运用[J].电子技术与软件工程,2021,218(24):240-241.
[2]刘俊.渗透测试在网络安全等保测评中的运用[J].电子技术与软件工程,2020,186(16):234-235.
[3]王世轶,吴江,张辉.渗透测试在网络安全等级保护测评中的应用[J].计算机应用与软件,2018,35(11):190-193.
[4]吴兰.Web 应用系统的渗透测试研究[J].电脑编程技巧与维护,2013,282(12):111-112.
[5]贺云龙.Web 应用渗透技术研究及安全防御方案设计分析[J].科技创新与应用,2022,12(29):189-192.

网络安全等级保护测评中网络安全现场测评方法

◆贺承玮 陈柯序

(新疆量子通信技术有限公司 新疆 830000)

摘要：网络安全等级保护测评工作是指测评机构根据客户的申请，对应用系统的安全能力进行验证和检测，从而判断客户的网络安全等级保护体系是否满足用户在国家、行业规定标准下要求，并提出相应整改意见。文章基于网络安全等级保护现场测评技术要求，分析现场安全测试重要性及测评过程，并针对网络安全等级保护现场测评存在的问题，提出相应的解决措施，旨在完成网络安全等级保护测评的目标。

关键词：网络安全；等级保护；现场测评

等级保护的核心目的是保障国家信息系统安全，根据《信息系统网络安全等级保护建设整改建议书》的要求，在指定的时间内，将针对系统建设时可能存在的问题和不足之处进行整改，并对整改结果进行检查。其中主要包括，基础设施、信息系统和信息管理等方面，测评机构对信息安全等级测评结果进行复核后出具《信息系统网络安全等级测评报告》并备案，同时将《信息系统网络安全等级测评报告》发往相关主管部门。因此，对关键业务资产及其应用范围内重要业务系统进行安全性评估是提升等级保护的重点工作，其中，现场安全测试是等级保护实施过程中非常重要的环节之一^[1]。

1 现场安全测试重要性

现场安全测试不仅对网络产品进行评估，而且在整个等级保护工作中都非常重要。例如，在基础支撑测评环节中，现场技术人员需要对终端用户进行身份识别、访问控制；需要现场实施网络环境和数据中心安全测评、渗透测试等。对于网络产品的现场测评环节，主要关注设备的配置是否满足要求；设备的物理和环境配置、设备功能、性能是否满足要求；设备管理机构是否齐全、是否配置了有效的安全防护措施；

终端系统和服务器系统的配置、操作系统、数据库等功能模块的安全性能等^[2-4]。

2 网络安全等级保护测评中网络安全现场测评过程

2.1 确定测评对象

针对要进行网络安全等级测评的单位而言，首先要确定本单位的信息系统是属于哪个等级。这里要注意的是，当确定好系统所属的等级后，可以按照该系统所在地区或单位对其重要性进行分类。不同等级的信息系统，在定级时所依据的要求也不一样。例如，如果一个信息系统在国内或省内占有重要地位，则定级时可能依据《中华人民共和国网络安全法》和国家有关部门规定进行定级，同时要明确在该系统内开展测评工作的单位名称及地址。

2.2 编制测评方案

(1)测评前，测评机构会根据客户需求进行详细的调研，包括企业信息系统的类型、数量、业务分布、运行环境以及对该系统的具体要求等。(2)测评机构根据客户提供的系统架构图，结合对客户业务实际情况的调研和了解，编写符合标